

RetailFlow

Data Governance Policy

Governance framework for the RetailFlow Platform designed by design

Document scope

Governance strategy, operating model, policies and standards, Alignment with the GDPR and ISO 27001 standards, consent management, quality controls, auditability, AI governance, KPIs, risk, change management and roadmap.

Official Deliverable - Data Governance - English - v2.0

RetailFlow - From customer events to trusted intelligence, governed by design.

1. Organization and Data Context

RetailFlow is a recently established company that develops the RetailFlow Platform, a Retail Intelligence solution for multi-category e-commerce organizations. The platform transforms customer events into trusted data, trusted data into customer intelligence, and customer intelligence into operational and strategic decision support. Because the organization is new, the governance framework has been designed from the beginning instead of being retrofitted after implementation.

The current implementation demonstrates this Governance by Design approach directly in the platform. Governance is not limited to a written policy: it is visible in the PostgreSQL schemas, FastAPI endpoints, Streamlit pages, Airflow workflows, quality controls, monitoring dashboards and CI/CD evidence. The latest version strengthens this model by making customer-level AI outputs dependent on analytics consent and by exposing implementation evidence through a dedicated Project Evidence page.

Value chain step	Governance control in RetailFlow
Customer events	Events are published through FastAPI and Redpanda, then validated by the consumer before persistence.
Trusted data	Valid events are stored in raw tables while invalid events are isolated in <code>governance.dead_letter_events</code> and logged in <code>data_quality_logs</code> .
Customer intelligence	Churn, CLV and segmentation outputs are served through FastAPI and displayed only under consent-aware governance rules.
Business decisions	Streamlit translates AI outputs into readable priorities, decisions and recommendations for authorized customers.
Continuous monitoring	Prometheus, Grafana, Airflow, Streamlit Observability and GitHub Actions provide operational evidence.

The data landscape includes customer profiles, consent indicators, orders, payments, returns, sessions, behavioral events, product data, derived features, AI predictions, governance logs and monitoring metrics. Customer-level data and AI-derived outputs are classified as confidential because they can influence business decisions and customer treatment. This makes governance a core requirement for the platform.

2. Governance Vision, Objectives and Scope

The governance vision is to ensure that customer data can be used as a trusted, compliant and valuable asset while preserving privacy, accountability, quality and auditability across the platform. The guiding principle remains that data should only become intelligence if it is governed, reliable, traceable and used for a legitimate purpose.

The framework covers data ownership, consent management, retention, anonymization, data quality, AI governance, auditability, risk management, accessibility, operational monitoring and

continuous improvement. It focuses first on the domains that create the most value and the most risk: customer data, behavioral events, transactions, product information, customer features, AI outputs, governance evidence and quality logs.

Objective	Updated implementation evidence
Clear data ownership	Executive Sponsor, Governance Council, Data Owner, Data Steward, Data Custodian, DPO, ML Owner, Business Owner and Data Users are defined.
Protect customer data	Consent flags, retention policies, anonymization workflow and audit logs are implemented in PostgreSQL and Airflow.
Consent-aware analytics	Customer Intelligence does not provide churn, CLV, segmentation and recommendations when analytics_consent is absent.
Control data quality	Validation rules, dead-letter events, quality summaries and Data Quality dashboard are operational.
Ensure auditability	Retention logs, quality logs, dead letters, ML reports, Prometheus metrics and CI/CD artifacts provide evidence.
Govern the AI lifecycle	AI Monitoring displays model registry, reports, drift, retraining runs and analytics_consent_count-based visibility.

The current governance implementation is strong for a demonstrator platform, while the future roadmap identifies the hardening actions required for a production enterprise environment.

3. Operating Model and Accountability

RetailFlow uses a hybrid operating model. A central governance layer defines shared policies, standards and controls, while domain actors apply them in their business and technical areas. This model is appropriate because RetailFlow spans business decision-making, data engineering, privacy, AI and operations. A fully centralized model would slow execution, while a fully decentralized model would weaken consistency and accountability.

Governance role	RetailFlow persona	Main responsibility
Executive Sponsor	Chief Data and Analytics Officer	Sponsors the program, validates priorities and removes cross-functional blockers.
Governance Council	Cross-functional committee	Approves policies, reviews risks, arbitrates decisions and reviews KPIs.
Data Owner	Head of Customer Intelligence	Owns definitions, usage priorities and data quality targets for customer intelligence.
Data Steward	Senior CRM and Analytics Manager	Reviews quality issues, consent usage, glossary definitions and operational adoption.
Data Custodian	Lead Data Engineer	Operates PostgreSQL, pipelines, retention workflows, backups, monitoring and technical controls.
DPO / Compliance Lead	Privacy and Compliance Manager	Oversees GDPR alignment, consent, retention, anonymization and audit readiness.
ML Owner	Lead Machine Learning Engineer	Owns model monitoring, drift review, retraining and explainability evidence.

Decision rights are aligned with these responsibilities. A new customer analytics use case is owned by the Data Owner and reviewed with the DPO, ML Owner and Business Owner. A new quality rule is owned by the Data Steward and implemented with the Data Custodian. Retention policy changes are owned by the DPO or Compliance Lead. Model retraining decisions are owned by the ML Owner and supported by metrics, drift reports and validation outputs.

The recommended cadence is monthly for governance KPI review, weekly for quality issue review, monthly for retention and ML monitoring reviews, and quarterly for the risk register, policies, accessibility and training. This cadence is realistic for a recently established organization and is supported by the dashboards and logs implemented in the platform.

4. Data Domains, Classification and Glossary

Governance is organized around the data domains that drive the RetailFlow value chain. The customer domain is governed for privacy, consent, retention and anonymization. The event domain is governed for validation, traceability and timeliness. The transaction domain is governed for accuracy and reporting reliability. The product domain is governed for completeness and catalog consistency. The AI output domain is governed for explainability, monitoring, versioning and responsible use.

Data domain	Classification	Governance focus
Customer profiles and consent	Confidential	Purpose limitation, consent, retention, anonymization, auditability and access control.
Behavioral events	Confidential	Validation, traceability, dead-letter handling and downstream feature reliability.
Transactions	Confidential	Financial consistency, reporting reliability and data quality controls.
Product catalog	Public / Internal	Catalog consistency, product references and internal price or margin sensitivity.
Customer features and ML predictions	Confidential	Consent-aware usage, explainability, versioning and AI governance.
Aggregated KPIs and monitoring	Internal	Operational visibility, dashboard reporting and platform observability.

The business glossary keeps key definitions consistent across business, technical and governance users. Analytics consent authorizes the use of customer data for analytics and intelligence exploration. Marketing consent authorizes marketing activation. Personalization consent authorizes individualized recommendations or experiences. A dead-letter event is an event rejected by validation and preserved for review. Churn risk, CLV and customer segment are AI outputs that must be interpreted as decision-support signals rather than automated final decisions.

5. Privacy, Consent, Retention and Anonymization

Privacy is embedded in RetailFlow through customer-level consent flags, retention policies and anonymization workflows. The platform tracks `marketing_consent`, `analytics_consent` and `personalization_consent`. The most important recent governance update is that analytics consent is no longer only a filter; it is also used as an application-level rule for customer intelligence display. When a customer has no analytics consent, churn, CLV, segmentation, raw AI profile and AI recommendations are not available because this data are not analyzed.

This decision is important because marketing consent and analytics consent serve different purposes. Marketing consent can support campaign activation, while analytics consent controls whether customer data can be used for analytics and customer intelligence exploration.

Privacy control	Current implementation
Analytics consent gate	Customer Intelligence displays AI predictions only when analytics_consent is granted; otherwise a warning message is shown.
Consent monitoring	Data Governance and AI Monitoring expose consent-based indicators, including analytics_consent.
Retention policy storage	governance.data_retention_policies stores retention rules and target domains.
Retention automation	Airflow retention_cleanup anonymizes expired customer records and disables consent flags.
Audit log	governance.retention_actions_log records policy, record, action, status, timestamp and execution component.

The retention and anonymization process reads the active retention policy, identifies eligible customer records, anonymizes personal fields, disables consent flags, updates account status and writes an audit record. This provides a concrete implementation of storage limitation and accountability. Future improvements should add role-based access control, API authentication, user-level audit logging, masking for sensitive attributes and formal privacy impact assessments for new use cases.

6. Data Quality Management

Data quality is governed at the pipeline level before data becomes trusted. Incoming events are validated for completeness, validity, referential consistency, timestamp usability and traceability. This prevents malformed or inconsistent events from silently contaminating raw events, customer features, dashboards or ML models. The strategy is preventive because validation happens before persistence, detective because rejected events are monitored, and corrective because dead-letter review allows root-cause analysis.

Invalid events are stored in governance.dead_letter_events with the original event identifier, event type, source topic, error reason, severity, raw payload and reprocessing status. Quality failures are also logged in governance.data_quality_logs. These tables are not only technical artifacts; they are governance evidence. The Data Quality page exposes latest dead-letter evidence, failed rules, severity distribution and remediation workflow, making quality visible to both technical and governance stakeholders.

Control type	Implementation
Preventive	FastAPI request structures, consumer validation, allowed event types, required identifiers, customer and product reference checks.
Detective	Dead-letter monitoring, quality summaries, Data Quality page, Airflow daily_data_quality and Prometheus/Grafana observability.
Corrective	Steward review, rule adjustment, pipeline correction by the Data Custodian and future controlled reprocessing.

A recent live demonstration intentionally generated an invalid event and confirmed that the platform isolates it in the dead-letter table with a clear error reason. This strengthens the governance proof because the system shows not only a policy, but also an operational control.

7. AI Governance, Responsible Intelligence and Auditability

RetailFlow includes three AI use cases: churn prediction, customer lifetime value estimation and customer segmentation. These outputs can influence retention, loyalty, upsell and targeting decisions, so they are governed as confidential decision-support information. The AI governance policy states that predictions support human judgment and must not automatically replace business review.

The latest implementation strengthens AI governance in two ways. First, the Customer Intelligence page does not provide churn, CLV, segmentation and AI recommendations when analytics consent is not granted. Second, the AI Monitoring page uses `analytics_consent` to represent the visible count of AI-authorized customer outputs.

AI governance control	Updated RetailFlow evidence
Purpose definition	Churn, CLV and segmentation each have a documented business purpose and interpretation.
Consent-aware access	Customer-level AI display is not possible when <code>analytics_consent</code> is absent.
Explainability	Business labels, decision framework and recommended actions translate model outputs into understandable guidance.
Monitoring	AI Monitoring displays model registry, reports, drift report, retraining runs and prediction availability.
Retraining	Airflow <code>ml_retraining</code> trains models, refreshes predictions, evaluates drift and logs retraining evidence.
CI/CD validation	GitHub Actions validates Python code, tests, Docker Compose, Docker builds and security reports.

Auditability is supported by several evidence sources: retention action logs, dead-letter events, data quality logs, Airflow DAG logs, ML reports, Prometheus metrics, Grafana dashboards, GitHub Actions artifacts and Streamlit Project Evidence. These sources allow RetailFlow to answer practical audit questions such as which customers have analytics consent, which records were anonymized, which events were rejected, why they were rejected, whether models are monitored and whether platform services are healthy.

8. Technology, KPIs and Risk Management

Governance is operationalized through the same platform components that support the rest of RetailFlow. PostgreSQL stores governance, consent, retention, quality and analytics data.

FastAPI exposes governance, quality and AI endpoints. Streamlit provides Data Governance, Data Quality, Customer Intelligence, AI Monitoring, Observability and Project Evidence pages. Airflow executes retention, quality, sales aggregation and ML retraining workflows. Prometheus and Grafana support operational monitoring, while GitHub Actions provides validation and security evidence.

Capability	Tooling and implementation
Governance storage	PostgreSQL schemas core, analytics and governance.
Retention and anonymization	Airflow retention_cleanup and governance.retention_actions_log.
Data quality	Consumer validation, dead-letter events, quality logs and Data Quality dashboard.
Consent-aware intelligence	Customer Intelligence page and AI Monitoring metrics based on analytics consent.
Operational monitoring	Prometheus targets, alert rules, Grafana dashboards and Streamlit Observability.
Security evidence	Readonly PostgreSQL role, example environment configuration, backup/restore scripts and CI security reports.

The KPI model remains focused on measurable governance adoption. Analytics consent coverage is targeted at 75 percent or more, marketing and personalization consent at 55 percent or more, retention action traceability at 100 percent, data quality execution at 95 percent or more, dead-letter rate below 2 percent in normal operation, ML monitoring coverage at 100 percent and governance review cadence at 90 percent or more. These KPIs connect governance to observable platform signals instead of treating governance as a static document.

Risk	Impact	Mitigation
Personal data exposure	High	Consent rules, classification, retention, anonymization, least privilege and future RBAC.
Consent misuse	High	Analytics consent gate in Customer Intelligence and policy review by DPO.
Retention failure	High	Retention policies, Airflow cleanup, audit logs and monthly compliance review.
Poor data quality	High	Validation rules, dead-letter isolation, quality logs and steward review.
ML drift or misuse	Medium	Drift monitoring, retraining DAG, model reports, human oversight and AI interpretation guidance.

Operational blind spot	Medium	Healthchecks, Prometheus alert rules, Grafana dashboards and Project Evidence navigation.
------------------------	--------	---

9. Implementation Status and Roadmap

RetailFlow already includes substantial governance implementation. The most important completed items are consent management, analytics consent enforcement, retention policy storage, retention cleanup, anonymization audit logs, validation rules, dead-letter handling, quality logs, Data Governance and Data Quality dashboards, AI Monitoring, Observability, CI/CD validation, security checks and the Project Evidence matrix.

Completed area	Current evidence location
Data Governance dashboard	Streamlit > Data Governance with operating model, consent, retention, risk, breach response and accessibility sections.
Customer Intelligence governance	Streamlit > Customer Intelligence with analytics consent filter and AI prediction masking.
Data Quality controls	Streamlit > Data Quality and PostgreSQL governance.dead_letter_events / data_quality_logs.
AI governance monitoring	Streamlit > AI Monitoring with registry, reports, drift, retraining and analytics_consent_count metrics.
Observability and alerting	Streamlit > Observability, Prometheus alert rules and Grafana dashboards.
Official evidence	Streamlit > Project Evidence with Final evidence matrix and Skills evidence matrix.

The roadmap remains realistic and production-oriented. The next governance improvements should include a formal data catalog, automated lineage, role-based access control, user-level audit logging, privacy impact assessments, extended AI approval workflows, governance training and stronger accessibility governance. These improvements are future hardening steps rather than gaps in the current demonstration.

Change management should begin with the most active users of customer and event data. The first training modules should cover governance fundamentals, consent and privacy, quality issue reporting, AI output interpretation and retention or anonymization responsibilities. The approach should remain practical: dashboards make governance visible, monthly KPI reviews create accountability, and user feedback helps extend governance to additional domains. Data governance must be inclusive; therefore, it must be adapted to make it accessible to as many people as possible.

10. Official Evidence Checklist

For an official assessment, the governance policy must be supported by visible evidence rather than only by written commitments. RetailFlow provides this evidence through its application

pages, database tables, orchestration workflows, monitoring tools and CI/CD artifacts. The table below summarizes where the main proofs can be verified during a demonstration or during a repository review.

Governance proof	Where to verify it
Consent-aware AI usage	Streamlit > Customer Intelligence and AI Monitoring; FastAPI /governance/summary.
Retention and anonymization	Airflow retention_cleanup and governance.retention_actions_log.
Data quality and dead-letter handling	Streamlit > Data Quality; governance.dead_letter_events and governance.data_quality_logs.
AI governance and monitoring	Streamlit > AI Monitoring; ml/model_registry.json and ml/reports/*.json.
Operational observability	Streamlit > Observability; Prometheus alert rules and Grafana dashboards.
Security and reliability controls	Readonly PostgreSQL role, backup/restore scripts, healthchecks and CI security reports.
Competency evidence	Streamlit > Project Evidence with Final evidence matrix and Skills evidence matrix.

11. Conclusion

The RetailFlow data governance framework is an operational component of the platform, inspired by the GDPR and the ISO 27001 standard. It covers ownership, policies, consent, retention, anonymization, quality, AI monitoring, auditability, security evidence, inclusion and continuous improvement. Its main strength is that governance is embedded directly in the platform design and demonstrated through working services, dashboards, logs, workflows and CI/CD evidence.

The updated implementation shows a mature governance posture for a Retail Intelligence demonstrator. Customer data is protected by consent and retention logic. Invalid data is isolated and traceable. AI outputs are monitored, explainable and blocked when analytics consent is absent. Platform health is observable through Prometheus and Grafana. The Project Evidence page connects these proofs to the official competency expectations. In one line, RetailFlow transforms customer events into trusted intelligence, governed by design.